GLOBAL ENTERPRISE POLICY: API SECURITY AND TRAFFIC CONTROL

Document ID: SEC-POL-2026-01

Effective Date: January 1, 2026

Last Reviewed: June 30, 2026

Owner: Chief Information Security Officer (CISO)

SECTION 1: API RATE LIMITING AND THROTTLING

All user-facing and internal API endpoints exposed by production microservices must implement automated rate limiting. Standard search, query, and AI retrieval endpoints are strictly capped at a maximum throughput of 100 requests per minute per client token. Any system architecture or runtime configuration proposing rate limits exceeding 100 requests per minute without written CISO approval is considered a major compliance violation. Rate limit configurations must be documented in the project's security architecture document.

SECTION 2: AUTHENTICATION STANDARDS

Every protected REST endpoint must validate incoming JWT tokens issued by the core identity provider. Anonymous access to document processing pipelines is strictly prohibited. Access tokens must have a maximum lifetime of 15 minutes. Refresh tokens must be stored in httpOnly cookies and must not be accessible via JavaScript. Token rotation must be implemented — each use of a refresh token must invalidate the previous token and issue a new one.

SECTION 3: INPUT VALIDATION AND SANITIZATION

All file upload endpoints must enforce strict file type allowlisting (not denylisting). Only explicitly permitted MIME types and extensions shall be accepted. Uploaded files must be scanned for malware before processing if the deployment environment is internet-facing. File size limits must be enforced at the application layer and the reverse proxy layer. Maximum upload size shall not exceed 25 MB per file without CISO exemption.

SECTION 4: LOGGING AND MONITORING

All authentication events (login, logout, token refresh, token revocation) must be logged with timestamp, user identifier, client IP, and outcome. All API errors with status codes 4xx and 5xx must be logged with request path, method, and user

identifier if authenticated. Logs must be retained for a minimum of 90 days and must be protected from tampering.

SECTION 5: PENETRATION TESTING REQUIREMENT

Every application handling user data or integrating with AI pipelines must undergo a penetration test by an approved external security vendor before its first production release. The penetration test report must be reviewed and signed off by the CISO. Critical and high-severity findings must be remediated before the application is approved for production deployment.

SECTION 6: DEPENDENCY AND SUPPLY CHAIN SECURITY

All third-party libraries and frameworks used in the application must be scanned for known vulnerabilities using an approved Software Composition Analysis (SCA) tool. Dependency scans must run on every CI/CD pipeline execution. Projects must maintain a Software Bill of Materials (SBOM) listing all direct and transitive dependencies with their versions. Any dependency with a known critical vulnerability must be patched or replaced within 7 calendar days of disclosure.

SECTION 7: SECURITY COMPLIANCE CHECKLIST

Every production application must complete the following before GA:

- SEC-REG-01: Implement rate limiting on all API endpoints with documented thresholds.
- SEC-REG-02: Enforce JWT authentication with token rotation on all protected routes.
- SEC-REG-03: Enforce file type allowlisting and size limits on upload endpoints.
- SEC-REG-04: Implement authentication event logging with 90-day retention.
- SEC-REG-05: Complete penetration test with CISO sign-off.
- SEC-REG-06: Complete SCA dependency scan with zero critical vulnerabilities.
- SEC-REG-07: Publish an SBOM for the application.

- SEC-REG-08: Obtain written CISO approval before deploying to production.